

Cyberbezpieczeństwo w organizacjach - przewodnik porządkujący

Jak czytać ten dokument

Cyberbezpieczeństwo w firmie najłatwiej zrozumieć, jeśli rozłoży się je na trzy warstwy, które na siebie nachodzą:

- **Regulacje** mówią, *co trzeba zrobić* i kto za to odpowiada (NIS2/KSC, DORA, RODO, normy ISO).
- **Organizacja** to *kto i jak* to robi - role, zespoły (np. SOC), procesy reagowania na incydenty.
- **Technologia** to *czym się to robi* - narzędzia (SIEM, EDR, firewalle), które wykrywają i blokują ataki.

Logika jest jednokierunkowa: **regulacja wymusza powstanie organizacji, a organizacja sięga po technologię**. Prawo nie mówi „kup SIEM” - mówi „musisz wykrywać i zgłaszać incydenty”, a żeby to robić, organizacja buduje SOC i wdraża SIEM. Trzymanie tej kolejności w głowie chroni przed najczęstszym błędem: kupowaniem narzędzi bez zrozumienia, jakiemu obowiązkowi i jakiemu ryzyku mają służyć.

Część 0. Fundamenty - po co to wszystko

Zanim wejdziemy w skróty, trzy pojęcia, które są fundamentem całej reszty.

Triada CIA - co właściwie chronimy

Bezpieczeństwo informacji sprowadza się do ochrony trzech właściwości (stąd „triada CIA”):

- **Poufność (Confidentiality)** - dostęp do danych mają tylko uprawnieni. Naruszenie = wyciek danych.
- **Integralność (Integrity)** - dane nie zostały niepostrzeżenie zmienione. Naruszenie = sfalszowany przelew, podmieniona faktura.
- **Dostępność (Availability)** - system działa, kiedy jest potrzebny. Naruszenie = ransomware, który blokuje firmę, albo atak DDoS.

Każdy atak i każdy mechanizm obrony da się przypisać do jednej z tych trzech kategorii. To uniwersalny „układ współrzędnych” całej dziedziny.

Ryzyko zamiast „czy jesteśmy bezpieczni”

Dojrzałe podejście nie pyta „czy jesteśmy bezpieczni” (odpowiedź zawsze brzmi „nie w 100%”), tylko **zarządza ryzykiem**: ryzyko = prawdopodobieństwo zdarzenia × jego skutek. Nie da się wyeliminować ryzyka, można je tylko obniżyć, przenosić (ubezpieczenie), akceptować albo unikać. To dlatego wszystkie nowoczesne regulacje mówią o „zarządzaniu ryzykiem”, a nie o konkretnej liście produktów.

Krajobraz zagrożeń - z czym walczymy

Najczęstsze kategorie, o których warto wiedzieć:

- **Ransomware** - złośliwe oprogramowanie szyfrujące dane i żądające okupu. Dziś najczęściej połączone z wyciekiem (tzw. podwójne wymuszenie).
- **Phishing / inżynieria społeczna** - oszukanie człowieka, nie maszyny (fałszywy e-mail, podszycie się pod prezesa). Statystycznie najczęstszy punkt wejścia.
- **Atak na łańcuch dostaw** - włamanie nie wprost do nas, lecz do naszego dostawcy oprogramowania lub usługi. Jeden z głównych powodów, dla których nowe regulacje kładą nacisk na nadzór nad dostawcami.
- **DDoS** - zalanie systemu ruchem tak, by przestał działać (atak na dostępność).
- **Zagrożenie wewnętrzne (insider)** - pracownik, świadomie lub nie.
- **APT (Advanced Persistent Threat)** - zaawansowany, długotrwały atak, zwykle sponsorowany przez państwo lub zorganizowaną grupę.

Część I. Regulacje

1.1. Mapa regulacji - kto czego dotyczy

W Europie nie ma „jednej ustawy o cyberbezpieczeństwie”. Jest zestaw aktów, które dotyczą różnych grup podmiotów. Najważniejsze rozróżnienie:

Akt	Kogo dotyczy	Czego dotyczy	Forma prawna
NIS2 / ustawa o KSC	szeroka gospodarka (energia, transport, zdrowie, IT, produkcja...)	ogólna odporność cyfrowa	dyrektywa UE → ustawa krajowa

Akt	Kogo dotyczy	Czego dotyczy	Forma prawna
DORA	sektor finansowy + jego dostawcy ICT	odporność operacyjna finansów	rozporządzenie UE (działa wprost)
RODO / GDPR	każdy, kto przetwarza dane osobowe	ochrona danych osobowych	rozporządzenie UE
ISO/IEC 27001	dobrowolnie, każdy	system zarządzania bezpieczeństwem informacji	norma (certyfikacja)

Kluczowa różnica prawna: **dyrektywa** (NIS2) wymaga „przepisania” do prawa krajowego - stąd polska ustawa o KSC. **Rozporządzenie** (DORA, RODO) obowiązuje bezpośrednio, identycznie w całej UE, bez ustawy krajowej.

Czy mój podmiot może podlegać kilku naraz? Tak. Bank podlega DORA i RODO. Szpital podlega NIS2/KSC i RODO. To normalne - regulacje się uzupełniają, nie wykluczają.

1.2. NIS2 i polska ustawa o KSC

Co to jest

NIS2 to dyrektywa UE 2022/2555 - druga, znacznie rozszerzona wersja unijnych przepisów o cyberbezpieczeństwie. Ponieważ dyrektywa wymaga wdrożenia krajowego, w Polsce realizuje ją **znowelizowana ustawa o Krajowym Systemie Cyberbezpieczeństwa (KSC, potocznie „KSC 2.0”)**.

Stan na dziś (ważne - to się niedawno zmieniło)

- Unijny termin na wdrożenie NIS2 minął **17 października 2024 r.** Polska, jak większość państw UE, spóźniła się.
- Polska nowelizacja ustawy o KSC **weszła w życie 3 kwietnia 2026 r.** (Dz.U. 2026 poz. 252). Od tej daty obowiązki są wiążące.
- Zakres podmiotowy gwałtownie się rozszerzył: z ok. **400** podmiotów (stary reżim „operatorów usług kluczowych”) do nawet **~30 000**.

Kogo dotyczy

Ustawa dzieli adresatów na dwie kategorie, według sektora (załączniki do ustawy) i wielkości:

- **Podmioty kluczowe** (art. 5 ust. 1) - najważniejsze sektory i więksi gracze; surowszy nadzór (m.in. audyt).
- **Podmioty ważne** (art. 5 ust. 2) - pozostałe objęte sektory; łagodniejszy reżim nadzoru.

Sektory to m.in. energetyka, transport, bankowość, zdrowie, infrastruktura cyfrowa, zarządzanie usługami ICT, dostawcy usług cyfrowych, a po nowelizacji także m.in. branża spożywcza, chemiczna, usługi pocztowe i gospodarka ściekowa. Próg wielkości co do zasady to średni przedsiębiorca (ok. 50 osób / 10 mln EUR), ale są wyjątki - np. **dostawcy usług zarządzanych w zakresie cyberbezpieczeństwa (MSSP) podlegają już od progu małego przedsiębiorcy** (ok. 10 osób / 2 mln EUR).

Praktyczny wniosek: „czy nas to dotyczy?” jest pierwszym i najważniejszym pytaniem. Decyduje sektor (kody PKD), wielkość i wyjątki. Istnieją bezpłatne testery (np. po numerze NIP), ale ostateczna kwalifikacja wymaga analizy ustawy.

Kluczowe terminy (liczone od 3 kwietnia 2026 dla podmiotów już istniejących)

Obowiązek	Termin
Wpis do wykazu podmiotów kluczowych/ważnych (rejestracja)	~6 mies. → 3 października 2026
Wdrożenie systemu zarządzania bezpieczeństwem (rozdz. 3 ustawy)	12 mies. → 3 kwietnia 2027
Pierwszy audyt (podmioty kluczowe)	24 mies. → 3 kwietnia 2028

Co trzeba zrobić (esencja obowiązków)

1. **Zarządzanie ryzykiem** - wdrożyć system bezpieczeństwa proporcjonalny do ryzyka (analiza ryzyka, polityki, szyfrowanie, kontrola dostępu, ciągłość działania, bezpieczeństwo łańcucha dostaw).
2. **Zgłaszanie incydentów** - do właściwego CSIRT, w rygorystycznych terminach (wczesne ostrzeżenie zwykle w 24 h, pełne zgłoszenie później). W polskiej implementacji za spóźnienie grożą dodatkowe kary.
3. **Nadzór nad łańcuchem dostaw** - ocena bezpieczeństwa dostawców.

- 4. **Audyty i nadzór** organu (w Polsce m.in. odpowiednie CSIRT-y i organy sektorowe).

Dwie rzeczy, które są naprawdę nowe względem starych przepisów

- **Osobista odpowiedzialność zarządu** (art. 20 NIS2). Cyberbezpieczeństwo przestaje być „sprawą działu IT” - staje się obowiązkiem nadzorczym członków zarządu, którzy mogą ponosić osobiste konsekwencje, łącznie z czasowym zawieszeniem w razie rażących zaniedbań.
- **Wysokie kary** - do **10 mln EUR lub 2% przychodu** dla podmiotu kluczowego.

1.3. DORA - odporność cyfrowa sektora finansowego

Co to jest

DORA (Digital Operational Resilience Act) to rozporządzenie UE 2022/2554 dotyczące **operacyjnej odporności cyfrowej sektora finansowego**. Jako rozporządzenie obowiązuje **bezpośrednio**, bez potrzeby ustawy krajowej.

Stan na dziś

- Weszło w życie 16 stycznia 2023 r., a **pełne stosowanie - od 17 stycznia 2025 r.** Od tej daty nadzór (w Polsce KNF) może w pełni egzekwować zgodność i nakładać sankcje.
- Okres 2023–2025 był czasem na dostosowanie.

Kogo dotyczy

Niemal cały sektor finansowy: banki, ubezpieczyciele, firmy inwestycyjne, instytucje płatnicze itp. - **oraz, co istotne, ich zewnętrzni dostawcy usług ICT** (np. dostawcy chmury). To pierwsza regulacja, która tak mocno wciąga dostawców technologii pod nadzór sektora finansowego.

Pięć filarów DORA

1. **Zarządzanie ryzykiem ICT** - ramy zarządzania ryzykiem technologicznym, za które odpowiada organ zarządzający.
2. **Zgłaszanie incydentów** - klasyfikacja i raportowanie poważnych incydentów ICT do organu nadzoru.
3. **Testowanie odporności cyfrowej** - regularne testy, a dla największych podmiotów zaawansowane testy penetracyjne oparte na scenariuszach zagrożeń (**TLPT** - Threat-Led Penetration Testing).
4. **Zarządzanie ryzykiem stron trzecich (ICT)** - nadzór nad dostawcami, wymogi umowne, rejestr dostawców; kluczowi dostawcy ICT podlegają bezpośredniemu nadzorowi europejskiemu.

5. **Wymiana informacji** - dzielenie się wiedzą o zagrożeniach między podmiotami.

NIS2 vs DORA - jak je odróżnić w jednym zdaniu: NIS2 to szeroka „podłoga” bezpieczeństwa dla całej gospodarki; DORA to wyspecjalizowany, surowszy reżim dla finansów. Tam, gdzie oba mogłyby kolidować, dla podmiotów finansowych DORA jest przepisem szczególnym (*lex specialis*).

1.4. Pozostałe regulacje warto znać (skrótowo)

- **RODO/GDPR** - ochrona *danych osobowych*. Często mylone z cyberbezpieczeństwem, ale to inna oś: RODO chroni prywatność, NIS2/DORA chronią ciągłość i odporność. Nakładają się przy wyciekach danych osobowych (podwójny obowiązek zgłoszenia: do organu ochrony danych i do CSIRT).
- **ISO/IEC 27001** - dobrowolna, międzynarodowa norma opisująca **System Zarządzania Bezpieczeństwem Informacji (ISMS)**. Certyfikat ISO 27001 jest częstym sposobem *udowodnienia*, że spełnia się wymogi NIS2/DORA - choć formalnie ich nie zastępuje.
- **NIST Cybersecurity Framework (CSF)** - amerykański, dobrowolny framework, bardzo popularny jako język wspólny. Porządkuje działania w funkcje: **Govern, Identify, Protect, Detect, Respond, Recover**. Świetna „mapa myśli” dla całej dziedziny.
- **AI Act** - reguluje systemy AI; styka się z cyberbezpieczeństwem tam, gdzie systemy AI muszą być odporne na manipulację i ataki. Osobny temat, ale coraz częściej powiązany.

Część II. Organizacja

Regulacja mówi „masz wykrywać i reagować”. Żeby to robić, potrzebne są role, zespoły i procesy. Oto jak to się układa.

2.1. Role i odpowiedzialności

- **Zarząd / organ zarządzający** - od czasu NIS2 i DORA *prawnie* odpowiedzialny za nadzór nad cyberbezpieczeństwem. To nie jest już delegowalne „w dół” bez reszty.
- **CISO (Chief Information Security Officer)** - szef bezpieczeństwa informacji. Odpowiada za strategię, ryzyko, zgodność i zespoły bezpieczeństwa. Łącznik między światem technicznym a zarządem.
- **CSO / CIO / CTO** - szefowie bezpieczeństwa (szerzej), informatyki i technologii; CISO często raportuje do jednego z nich lub bezpośrednio do zarządu.
- **DPO (Data Protection Officer / Inspektor Ochrony Danych)** - rola z RODO; pilnuje danych osobowych. Bywa mylona z CISO, ale to inna funkcja.

- **Analitycy bezpieczeństwa** - ludzie „od pierwszej linii”, zwykle w SOC (niżej).

2.2. SOC - Security Operations Center

Co to jest

SOC to centrum operacji bezpieczeństwa - zespół (i jego narzędzia oraz procesy), którego zadaniem jest **całodobowe monitorowanie, wykrywanie, analiza i reagowanie** na zagrożenia. Najprostsza analogia: **to „centrum monitoringu” lub „dyspozytornia 112” dla infrastruktury cyfrowej firmy** - ktoś patrzy na ekrany 24/7, a gdy zapali się alarm, uruchamia procedurę.

Z czego się składa - ludzie, procesy, technologia

SOC to nie produkt, który się kupuje, tylko zestawienie trzech elementów:

- **Ludzie** - analitycy w kilku poziomach:
 - **L1 (Tier 1)** - triaż: przegląda alarmy, odsiewa fałszywe, eskaluje istotne.
 - **L2 (Tier 2)** - głębsza analiza incydentu, ustalanie, co się stało i jak daleko sięga.
 - **L3 (Tier 3)** - eksperci: threat hunting (aktywne polowanie na ukryte zagrożenia), analiza złośliwego oprogramowania, najtrudniejsze incydenty.
 - **SOC Manager** - kieruje całością.
- **Procesy** - udokumentowane procedury (playbooki): co robić przy danym typie alarmu, jak eskalować, jak zgłaszać.
- **Technologia** - przede wszystkim SIEM i SOAR (Część III).

Modele organizacyjne SOC

Nie każda firma buduje SOC od zera. Trzy podejścia:

Model	Na czym polega	Dla kogo
In-house (własny)	własny zespół i narzędzia	duże organizacje, sektor regulowany, własne dane wrażliwe
Outsourcing / MSSP	usługę świadczy zewnętrzny dostawca (Managed Security Service Provider)	średnie firmy bez własnych kompetencji

Model	Na czym polega	Dla kogo
Hybrydowy	część własna (np. decyzje, kontekst biznesowy), część kupiona (np. monitoring 24/7)	najczęstszy wybór w praktyce

Pojęcie pokrewne: **MDR (Managed Detection and Response)** - popularna usługa „SOC jako usługa”, w której zewnętrzny dostawca nie tylko monitoruje, ale i aktywnie reaguje.

2.3. SOC a CSIRT/CERT - łatwe do pomylenia

- **SOC** działa *operacyjnie i ciągle* - to wewnętrzna „dyspozytornia” firmy, patrząca na bieżąco.
- **CSIRT / CERT (Computer Security Incident Response Team)** to zespół *reagowania na incydenty*. Bywa wewnętrzny, ale w kontekście regulacji najważniejsze są **krajowe CSIRT-y** (w Polsce m.in. CSIRT NASK, CSIRT GOV, CSIRT MON), do których - zgodnie z ustawą o KSC - zgłasza się incydenty.

Uproszczenie: **SOC patrzy non-stop; CSIRT wkracza, gdy trzeba ugasić pożar i koordynować odpowiedź** (a krajowy CSIRT to także adresat ustawowych zgłoszeń).

2.4. Kluczowe procesy

- **Zarządzanie incydentami (Incident Response)** - cykl: przygotowanie → wykrycie → analiza → powstrzymanie → usunięcie → odtworzenie → wnioski. To ten proces realizuje regulacyjny obowiązek „zgłaszania i reagowania”.
- **Zarządzanie podatnościami (Vulnerability Management)** - ciągłe szukanie i łatanie słabych punktów, zanim zrobi to atakujący.
- **Threat Intelligence** - zbieranie wiedzy o aktualnych zagrożeniach i grupach atakujących, by wiedzieć, czego szukać.
- **Ciągłość działania i odtwarzanie po awarii (BCP/DRP)** - plany na wypadek poważnego incydentu, tak by firma nie stanęła. To serce „odporności” w DORA.

2.5. Frameworki ładu (governance)

Żeby to wszystko nie było chaosem, organizacje opierają się na ramach:

- **ISO/IEC 27001** - buduje formalny ISMS (polityki, role, cykl ciągłego doskonalenia).

- **NIST CSF** - porządkuje całość w sześć funkcji (Govern–Identify–Protect–Detect–Respond–Recover); dobry język do rozmowy z zarządem.
- **CIS Controls** - konkretna, priorytetyzowana lista zabezpieczeń technicznych „od czego zacząć”.

Część III. Technologia

Tu pojawiają się narzędzia. Najważniejsza zasada porządkująca to **obrona warstwowa (defense in depth)**: nie ma jednego „magicznego pudełka”, jest wiele warstw, z których każda łapie to, co przepuści poprzednia.

3.1. Narzędzia monitoringu i reagowania (rdzeń SOC)

- **SIEM (Security Information and Event Management)** - *mózg SOC*. Zbiera logi i zdarzenia z całej infrastruktury (serwery, sieć, aplikacje), koreluje je i generuje alarmy. Analogia: **centrala, do której spływają wszystkie kamery i czujniki, i która zapala alarm, gdy coś nie pasuje**. Przykłady kategorii: Splunk, Microsoft Sentinel, Elastic.
- **SOAR (Security Orchestration, Automation and Response)** - *automatyka*. Bierze alarmy z SIEM i wykonuje zautomatyzowane reakcje wg playbooków (np. automatycznie odcina zainfekowany komputer). Odciąża analityków od powtarzalnej pracy.
- **EDR (Endpoint Detection and Response)** - ochrona i monitoring *urządzeń końcowych* (laptopy, serwery). Następca klasycznego antywirusa - nie tylko blokuje, ale rejestruje, co się działo, i pozwala reagować.
- **XDR (Extended Detection and Response)** - rozszerzenie EDR o dane z sieci, poczty, chmury - szersze pole widzenia w jednym narzędziu.
- **NDR (Network Detection and Response)** - wykrywanie zagrożeń na podstawie *ruchu sieciowego*.
- **MDR (Managed Detection and Response)** - j.w., ale jako usługa (patrz Część II).

3.2. Ochrona sieci i brzegu

- **Firewall (zapora sieciowa)** - kontroluje, jaki ruch wchodzi i wychodzi. Podstawowa warstwa; nowoczesne to **NGFW (Next-Generation Firewall)** z głębszą analizą.
- **IDS / IPS (Intrusion Detection / Prevention System)** - systemy wykrywania (IDS - alarmuje) i zapobiegania (IPS - blokuje) włamaniom.
- **WAF (Web Application Firewall)** - zapora dedykowana aplikacjom webowym.
- **VPN / segmentacja sieci** - bezpieczny dostęp zdalny i dzielenie sieci na strefy, by włamanie w jednym miejscu nie dało dostępu do wszystkiego.

3.3. Tożsamość i dostęp (dziś najważniejsza warstwa)

- **IAM (Identity and Access Management)** - zarządzanie tym, kto i do czego ma dostęp.
- **MFA (Multi-Factor Authentication)** - uwierzytelnianie wieloskładnikowe (hasło + np. kod z telefonu). Pojedyncze, najskuteczniejsze zabezpieczenie przeciw przejęciu konta.
- **PAM (Privileged Access Management)** - szczególna ochrona kont uprzywilejowanych (administratorów), bo to one są najcenniejszym celem.
- **Zero Trust** - nie „filozofia produktu”, tylko *podejście*: „nigdy nie ufaj, zawsze weryfikuj”. Zakłada, że żaden użytkownik ani urządzenie nie jest zaufane domyślnie, nawet wewnątrz sieci. Stopniowo zastępuje stary model „twardej skorupy, miękkiego środka”.

3.4. Ochrona danych i ciągłość

- **Szyfrowanie (encryption)** - danych „w spoczynku” (na dyskach) i „w tranzycie” (w sieci). Chroni poufność nawet po wycieku.
- **Kopie zapasowe (backup)** - i ich regularne *testowanie odtwarzania*. Najlepsza obrona przed ransomware. Zasada 3-2-1: 3 kopie, 2 nośniki, 1 poza siedzibą.
- **DLP (Data Loss Prevention)** - wykrywanie i blokowanie wycieku wrażliwych danych na zewnątrz.

3.5. Ofensywa kontrolowana (testowanie)

- **Testy penetracyjne (pentesty)** - kontrolowane „ataki” zlecane, by znaleźć dziury, zanim zrobi to przeciwnik.
- **Red team / Blue team** - symulacje: red team atakuje, blue team broni. **TLPT** z DORA to zaawansowana, regulowana odmiana takich testów dla największych instytucji finansowych.

Część IV. Spięcie wszystkiego - jak warstwy się łączą

Najlepiej pokazać to na przykładzie: **regulacja** → **organizacja** → **technologia**.

Wymóg regulacyjny	Co robi organizacja	Czym (technologia)
„Wykrywaj incydenty” (NIS2/DORA)	SOC monitoruje 24/7	SIEM + EDR/XDR
„Zgłaszaj incydenty w terminie”	proces Incident Response, zgłoszenie do CSIRT/KNF	SOAR, system ticketowy
„Zarządzaj ryzykiem łańcucha dostaw”	ocena i nadzór dostawców	rejestr dostawców, oceny ryzyka
„Zapewnij ciągłość działania”	plany BCP/DRP, testy	backup 3-2-1, redundancja
„Kontroluj dostęp”	polityki tożsamości, zasada minimalnych uprawnień	IAM, MFA, PAM, Zero Trust
„Testuj odporność” (DORA TLPT)	red/blue team, pentesty	narzędzia ofensywne, symulacje

Czytelny morał: **technologia bez procesów to wydatek, a nie bezpieczeństwo**. SIEM bez analityków generuje alarmy, których nikt nie czyta. Dlatego dojrzałe wdrożenie idzie w kolejności: zrozum obowiązek i ryzyko → utóż proces i role → dobierz narzędzie.

Słownik skrótów

Skrót	Rozwinięcie	W jednym zdaniu
APT	Advanced Persistent Threat	zaawansowany, długotrwały atak
BCP / DRP	Business Continuity / Disaster Recovery Plan	plany utrzymania i odtworzenia działania
CIA	Confidentiality, Integrity, Availability	trzy filary bezpieczeństwa informacji
CISO	Chief Information Security Officer	szef bezpieczeństwa informacji
CSIRT / CERT	Computer Security Incident Response Team	zespół reagowania na incydenty

Skrót	Rozwinięcie	W jednym zdaniu
DLP	Data Loss Prevention	zapobieganie wyciekowi danych
DORA	Digital Operational Resilience Act	unijne rozporządzenie dla finansów
DPO	Data Protection Officer / IOD	inspektor ochrony danych (RODO)
EDR / XDR / NDR / MDR	(Endpoint/Extended/Network/Managed) Detection and Response	rodziny narzędzi/usług wykrywania i reakcji
IAM / PAM	Identity / Privileged Access Management	zarządzanie tożsamością i kontami uprzywilejowanymi
IDS / IPS	Intrusion Detection / Prevention System	wykrywanie / blokowanie włamań
ISMS	Information Security Management System	system zarządzania bezpieczeństwem (ISO 27001)
KSC	Krajowy System Cyberbezpieczeństwa	polska ustawa wdrażająca NIS2
MFA	Multi-Factor Authentication	uwierzytelnianie wieloskładnikowe
MSSP	Managed Security Service Provider	dostawca usług bezpieczeństwa
NIS2	Network and Information Security Directive 2	unijna dyrektywa o cyberbezpieczeństwie
NIST CSF	NIST Cybersecurity Framework	popularny framework porządkujący
SIEM	Security Information and Event Management	„mózg” SOC - zbiera i koreluje zdarzenia
SOAR	Security Orchestration, Automation and Response	automatyzacja reakcji

Skrót	Rozwinięcie	W jednym zdaniu
SOC	Security Operations Center	centrum monitoringu i reagowania
TLPT	Threat-Led Penetration Testing	zaawansowane testy odporności (DORA)
WAF	Web Application Firewall	zapora dla aplikacji webowych

Załącznik: ścieżka „od czego zacząć” w organizacji

1. **Zdiagnozuj status regulacyjny** - czy podlegamy NIS2/KSC i/lub DORA? (sektor, wielkość, wyjątki).
2. **Wyznacz odpowiedzialność** - zarząd + CISO; jasny właściciel tematu.
3. **Zrób analizę ryzyka i lukę (gap analysis)** - gdzie jesteśmy vs. czego wymaga prawo.
4. **Ułóż procesy zanim kupisz narzędzia** - zwłaszcza reagowanie na incydenty i zgłaszanie.
5. **Zdecyduj o modelu SOC** - własny / MSSP / hybryda.
6. **Dobierz technologię warstwowo** - najpierw podstawy (MFA, backup, EDR, segmentacja), potem SIEM/SOAR.
7. **Testuj i doskonal, cyklicznie** - audyty, pentesty, aktualizacja planów.